
SOC 2 for NBFC

The definitive implementation playbook

From Fresher to Expert, with NBFC-specific overlays, real examples, document templates, and an end-to-end case study.

What you will be able to do after reading this guide:

- Explain SOC 2 to a CFO in two minutes
- Scope a SOC 2 engagement for any NBFC product (lending, collections, KYC, co-lending)
- Build the full control matrix mapped to Trust Services Criteria
- Run a 9-month SOC 2 Type II program from gap assessment to audit delivery
- Prepare artefacts for every Common Criterion and each selected TSC
- Handle NBFC-specific subservice organisations (cloud, KYC vendor, payment gateway, co-lending bank)
- Pass the audit on the first attempt

Edition v1.0 | July 2026

Frameworks covered: AICPA TSC 2017 (rev 2022), SSAE-18/ISAE 3000, ISO 27001/27002:2022, NIST CSF 2.0, RBI Master Direction on Outsourcing 2021, RBI IT/Cyber Framework 2023, India DPDP Act 2023.

Table of Contents

Placeholder for table of contents	0
-----------------------------------	---

Foundations: what SOC 2 is, who needs it, and why NBFCs care

Chapter 1. Socializing SOC 2 in two minutes

SOC 2 (Service Organization Control 2) is an independent auditor's report on the controls a service organisation operates. It exists because your customers (especially their auditors) want assurance that you handle their data safely. It is *not* a certification like ISO 27001, it is an **attestation report** issued by a licensed CPA firm under AICPA standards (SSAE-18 / ISAE 3000/3402).

Three sentences to memorise:

- SOC 2 reports on **controls** at a **service organisation** against **Trust Services Criteria**.
- There are four report types: SOC 1, SOC 2, SOC 3, and SOC for Cybersecurity. **SOC 2 is the one B2B SaaS and fintech clients ask for.**
- SOC 2 Type I = design at a point in time. SOC 2 Type II = design + operating effectiveness over 6-12 months.

Chapter 2. Why NBFCs specifically need SOC 2

An NBFC (Non-Banking Financial Company) registered with the Reserve Bank of India delivers lending, leasing, micro-finance, or factoring services. Modern NBFCs run on a tech stack: a Loan Management System (LMS), a Customer Relationship platform, a mobile app for borrowers, KYC/eKYC services, CIBIL/Credit Bureaus, bank-integrated payment gateways, and increasingly, co-lending partnerships with banks.

NBFC pain points that drive SOC 2 demand

Your enterprise clients (banks, insurance, fintech aggregators, marketplaces, even global SaaS companies acting as data principals) routinely require one of: **SOC 2 Type II, ISO 27001, PCI DSS**. Some Big-Tech customers (Salesforce, AWS, Zoho) refuse onboarding of NBFC vendors that lack SOC 2. SOC 2 is typically the *cheapest gating credential* because it is reusable across many customers.

Chapter 3. The five Trust Services Criteria (TSC)

AICPA's Trust Services Criteria is a set of 61+ criteria grouped into five categories. You pick the categories your report covers.

Code	Category	When NBFC includes it
Security (Common Criteria CC-1)	Information security baseline. Always included.	Always.
Availability (A)	Uptime, performance monitoring, DR.	If the NBFC app is customer-facing (digital lending app, mobile wallet).
Confidentiality (C)	Protection of confidential data.	If processing data labelled confidential (financials, credit reports).
Processing Integrity (PI)	Completeness, accuracy, timeliness of processing.	If payment, settlement, reconciliation is in scope.

Privacy (P)	Personal data handling aligned to AIOPA and personal data of EU/UK/US residents or DPDP-regulated
-------------	---

Pick the right category mix (cheat sheet)

NBFC doing digital lending + co-lending with banks: Security, Availability, Confidentiality, Processing Integrity.
NBFC serving US/EU clients or with EU data subjects: add Privacy.
NBFC running a pure internal lending model: Security is mandatory; pick criteria based on what your customer contract requires.
Rule of thumb: include only what your customers ask for - including extra TSCs widens audit scope and cost.

Chapter 4. Type I vs Type II - the brutal truth

Aspect	Type I	Type II
What auditor opines on	Design of controls at a specific date.	Design and operating effectiveness over a period (3
Time to deliver	4-8 weeks from kickoff	Minimum 6 months observation window + 4-8 weeks audit
Cost (rough order)	■6L - ■15L for NBFC scope	■18L - ■60L for NBFC scope
Sales value	Good enough for mid-market prospects	Required by enterprise, banks, regulated entities
Risk for client	Doesn't prove controls actually work	Controls must operate without material exceptions
When to use	First SOC 2 report; urgent sales cycle	Renewals; enterprise contracts; mature program

Type II observation window - the single biggest decision

Most NBFCs choose a **12-month look-back window** ended Sep 30 / Dec 31 to align with calendars of their bank partners and statutory audit. A **6-month window** is faster but you must have evidence for the entire 6-month period. **3 months** is only used when you absolutely need a report in <6 months. Auditor sentiment: a clean 12-month report is the gold standard.

Chapter 5. Scope statement - get this wrong and the audit is wasted

The scope statement is what the auditor is opining on. It must list every in-scope system, location, service, and supporting infrastructure component. A non-exhaustive template:

Sample scope statement (RapidLend NBFC Pvt Ltd):

Sample scope statement

This report covers the controls at **RapidLend NBFC Private Limited** ('RapidLend') related to the **Digital Lending Platform, Loan Origination System (LOS), Loan Management System (LMS), Customer Mobile Application (Android/iOS), Co-Lending Integration Layer (API), and supporting KYC/CIBIL/Payment Gateway integrations**, hosted in **AWS Mumbai (ap-south-1) and AWS Singapore (ap-southeast-1)**, operated by RapidLend personnel and subservice organisations listed in Section 5.2. The period covered is **01 Jan 2025 to 31 Dec 2025**. The Trust Services Criteria covered are Security, Availability, Confidentiality, and Processing Integrity.

The Trust Services Criteria, NBFC overlay, and regulator mapping

Chapter 6. The Common Criteria (CC) - the governance spine

These nine series (CC1-CC9) cover governance, risk, communication, monitoring, logical & physical access, system operations, change management, and risk mitigation. They are **mandatory** in every SOC 2 report. Total: 33 individual criteria.

CC1 - Control Environment (Criteria CC1.1 to CC1.5)

- **CC1.1** - Demonstrates commitment to integrity & ethical values. *Evidence:* Code of Conduct, annual acknowledgement, ethics training records.
- **CC1.2** - Board of directors exercises oversight. *Evidence:* Board charter, cyber/IT committee charter, board meeting minutes where security is discussed.
- **CC1.3** - Management establishes structures, reporting lines, and authorities. *Evidence:* Org chart, RACI for security, role descriptions.
- **CC1.4** - Demonstrates commitment to competence. *Evidence:* Hiring checklists, role-based training, annual performance reviews.
- **CC1.5** - Accountable individuals. *Evidence:* Sign-offs on policies, documented ownership of controls.

NBFC-specific CC1 context

For Indian NBFCs the 'Board' is your NBFC board as registered with RBI. Show **RBI Master Direction compliance** in CC1 evidence: include cyber in quarterly board agenda, document the Cyber Security Committee (if applicable) per RBI IT Framework 2023 §13, and reference the Risk Management Committee that owns information security risk.

CC2 - Communication & Information (CC2.1 to CC2.3)

- **CC2.1** - Obtain / generate relevant quality information to support functioning of internal controls. *Evidence:* MIS dashboards, security KPIs, KRIs.
- **CC2.2** - Internally communicate information necessary to support the functioning of internal control. *Evidence:* all-hands, security awareness, internal phishing reports.
- **CC2.3** - Externally communicate information necessary to support the functioning of internal control. *Evidence:* privacy notice, status page, customer SLA reports, RBI notifications where required.

NBFC CC2 - status page, regulator & customer notification

For an NBFC, **CC2.3** is partly tied to RBI's *Master Direction on Outsourcing of IT Services 2021* and the *IT Framework 2023*: any major incident must be reported to RBI within 2 hours for critical incidents and 6 hours for high severity. Build a runbook that lists external stakeholders (RBI, customers, partners, credit bureaus, co-lending banks) and the channel + SLA for each.

CC3 - Risk Assessment (CC3.1 to CC3.4)

- **CC3.1** - Specifies suitable objectives. Evidence: documented security objectives tied to business.
- **CC3.2** - Identifies and analyses risk. Evidence: enterprise risk assessment register, threat catalogue.
- **CC3.3** - Considers the potential for fraud. Evidence: fraud risk assessment, AML/CFT control list.
- **CC3.4** - Identifies and analyses significant changes. Evidence: change advisory board records, new product risk reviews.

CC4 - Monitoring Activities (CC4.1 and CC4.2)

- **CC4.1** - Ongoing and separate evaluations. Evidence: weekly/monthly control monitoring, internal audit program.
- **CC4.2** - Evaluation and communication of deficiencies. Evidence: issue log, remediation tracker, management reporting.

CC5 - Control Activities (CC5.1 to CC5.3)

- **CC5.1** - Selects and develops control activities. Evidence: control library, mapping to risks.
- **CC5.2** - Selects and develops general technology controls. Evidence: baseline configuration, hardened images, patch program.
- **CC5.3** - Deploys through policies and procedures. Evidence: policy library, acknowledgement logs.

CC6 - Logical & Physical Access (CC6.1 to CC6.8) - the largest area

- **CC6.1** - Logical access security software, infrastructure, architectures.
- **CC6.2** - New / modified user access is authorised before provisioning.
- **CC6.3** - Authorised, modified, removed; access reviews.
- **CC6.4** - Restricts physical access.
- **CC6.5** - Discontinues logical & physical protection of assets.
- **CC6.6** - Implements logical access security measures for data in transit / at rest (encryption).
- **CC6.7** - Restricts the transmission, movement, removal of information to authorised users.
- **CC6.8** - Implements controls to prevent or detect and act upon the introduction of unauthorised or malicious software.

NBFC CC6.6 (encryption) specific guidance

For an NBFC, encrypt: (a) all **PII/Aadhaar stored** at rest using AES-256 (UIDAI guideline aligned), (b) all **loan application data** in transit using TLS 1.2+, (c) all **CIBIL report pulls** both in transit and at rest (CIBCriff/HDFC-CIBIL contract requirement), (d) **database backups** using KMS-managed keys with annual rotation, (e) **laptops** full-disk BitLocker/FileVault enforced via MDM.

CC7 - System Operations (CC7.1 to CC7.5)

- **CC7.1** - Detects / monitors configuration vulnerabilities.
- **CC7.2** - Monitors system components and operation.
- **CC7.3** - Evaluates security events to determine response.
- **CC7.4** - Responds to identified security incidents (IR).
- **CC7.5** - Recovery from identified security incidents (BCP/DR).

NBFC CC7.4 (IR) - the 2-hour RBI timer

RBI IT Framework 2023 mandates reporting of **cyber incidents** to RBI within 2 hours of detection for critical incidents (data breach, ransomware, fraud > ₹25 lakh) and 6 hours for high severity. The SOC 2 narrative for CC7.4 must show: (a) detection sources (SIEM, IDS, fraud alerts), (b) on-call rota, (c) escalation matrix, (d) RBI notification template, (e) regulatory logging.

CC8 - Change Management (CC8.1)

Authorises, designs, develops, tests, and implements changes to infrastructure, data, software, and procedures. *Watch out for:* emergency changes still need a documented change record; production deploys mapped to change tickets; four-eyes principle for production.

NBFC CC8.1 - emergency change loophole

Many NBFCs have a heavy weekend push schedule. Regulator-side (RBI) and SOC 2 require that **emergency changes** are still logged, approved by a second engineer, tested in staging, evidenced by CI/CD pipeline logs, and reviewed the next business day. A common audit finding: production deploys without a corresponding Jira ticket.

CC9 - Risk Mitigation (CC9.1 and CC9.2)

Identifies, selects, and develops risk mitigation activities; assesses and manages risks associated with vendors and business partners. *This is where subservice organisations are scrutinised.*

Chapter 7. The 'C' Series - Confidentiality Criteria (optional category)

- **C1** - Identifies confidential information, determines how to protect it.
- **C1.1** - Removes confidential information when no longer needed.
- **C1.2** - Retains confidential information per policy.

Chapter 8. The 'A' Series - Availability Criteria

- **A1.1** - Maintains current processing capacity and demand.
- **A1.2** - Authorises, designs, develops, acquires, implements, operates, approves, maintains, and monitors infrastructure.
- **A1.3** - Tests recovery plan procedures.

NBFC A1.3 - DR test evidence

RBI IT Framework 2023 §18 mandates annual DR drill for NBFCs. You must demonstrate **at least one documented BCP/DR exercise during the SOC 2 observation period**. Show: scenario, RTO/RPO achieved, participants, outcomes, lessons learned. Aim for an annual tabletop + a partial production failover.

Chapter 9. The 'PI' Series - Processing Integrity Criteria

- **PI1.1-PI1.5** - Obtaining, storing, processing, delivering data accurately & completely.
- **PI1.6** - Implements policies & procedures to support processing integrity.

NBFC PI1 examples - real NBFC processing integrity

PI1.2 (Inputs are accurate): eKYC validation, Aadhaar XML parse, CIBIL pull reconciliation. **PI1.3 (Stored accurately):** loan amount, interest rate, tenure persisted in LMS reconciled to LOS. **PI1.4 (Processed as designed):** EMI calculation unit test 100% pass; disbursement job reconciliation with bank statement.

Auditor will pull samples of disbursements and reconcile every number. Build a daily reconciliation report.

Chapter 10. The 'P' Series - Privacy Criteria (only include if you do privacy)

- **P1-P8** - Notice & consent, choice & opt-in, personal info collection, use/retention/disposal, access/correction, disclosure to third parties, quality, monitoring & enforcement.

DPDP Act 2023 + Privacy mapping for Indian NBFCs

India DPDP Act 2023 sections that map to AICPA Privacy:

- S.4 (notice) ↔ P1.1—P1.4 notice & choice
- S.6 (purpose limitation) ↔ P2.1 use limitation
- S.7 (storage limitation) ↔ P3.1, P4 retention & disposal
- S.8 (rights of data principal) ↔ P5.1 access, P6 correction
- S.10 (fiduciary obligations) ↔ P7, P8 monitoring/enforcement

Cross-border transfer (S.14) and significant data fiduciary obligations must be addressed via separate SOP.

Chapter 11. NBFC Regulatory Overlay (RBI + DPDP + other)

NBFCs operate in a regulated matrix. SOC 2 & these regulations must be consistent - never contradictory. Build a regulatory mapping sheet that points RBI / DPDP clauses to SOC 2 controls (so one piece of evidence satisfies both).

Regulator / Act	Clause	What NBFC must do	SOC 2 mapping
RBI Master Direction on Outsourcing of IT Services 2021	Para 5.1	Investigation of all outsourcing arrangements	CC9.2 / CC9.3
RBI IT Framework for NBFCs 2023	§16 Security Committee	Establishing committee chaired by MD/CEO/ED, quarterly meetings	CC12 / CC12.2
RBI IT Framework 2023	§17 Incident Reporting	Report cyber incident within 2-6 hours of detection	CC7.3 / CC7.4
RBI IT Framework 2023	§18 Business Continuity	Annual DR drill, RTO/RPO targets, Offsite Backup	CC7.5 / CC7.6
RBI Digital Lending Guidelines 2022	Deliverables, data privacy, partner conduct	Disy, partner conduct fees, partner assessment	CC8.3 / CC8.5
India DPDP Act 2023	§4 Notice & consent	Notice + explicit consent before processing	CC1.1 / CC1.2
India DPDP Act 2023	Cross-border transfer	Restricted, only to notified countries	CC1.1 / CC1.1
IT Act 2000 (CSP Guidelines)	§11 Security Practices	Reasonable security practices	All CC + C
CERT-In Directions 2022	Incident reporting within 6 hours	Log retention 180 days, sync NTF	CC7.1 / CC7.3

Running the SOC 2 Type II program end-to-end

Chapter 12. The 9-month implementation roadmap

Phase	Weeks	Activities
1. Mobilise	0-2	Charter approved, auditor selected (Big 4 / mid-tier), Steering Committee (CxO + CISO + IT Head)
2. Scope & Inventory	2-4	Scope statement finalized, asset inventory built (apps, infra, data, vendors), data flow diagram dra
3. Gap Assessment	4-6	TSC-by-TSC walkthrough, controls assessed (Implemented / Partial / Not implemented), gap rem
4. Remediation	6-24	Policies written, controls implemented (IAM, log mgmt, vuln mgmt, change mgmt, IR, DLP, encryp
5. Pre-Audit Readiness	24-30	Internal controls-test dry run, control owners trained on sampling, exceptions log, evidence catalo
6. Observation Window	30-70	Controls run, evidence continuously collected. Spot audits monthly. Minor exceptions remediated
7. Audit Fieldwork	70-78	Auditor primes sample lists, weekly calls, evidence requested through GRC platform, interviews s
8. Report Issuance	78-86	Auditor's draft report reviewed, management response on exceptions drafted, SOC 2 Type II repo
9. Operate	86+	Continuous control monitoring, quarterly CCO review, annual refresh, customer-facing trust port

Chapter 13. Phase 1 - kick-off charter contents

- Executive sponsor (CRO / CFO / CTO) - signature authority unless modified
- Sponsor (CISO) - drives day-to-day delivery
- Steering Committee - meets bi-weekly; covers status, blockers, escalations
- Working Group - daily tactical standups
- Auditor engagement letter signed (engagement partner, fee, in-scope TSCs, observation window)
- Tracker / GRC platform onboarded (Drata, Vanta, Secureframe, Tugboat Logic recommended)
- RACI file uploaded in tracker
- Communication plan to leadership (status report format)
- Definition of success: (a) clean SOC 2 Type II report, (b) within budget, (c) delivered on time

Chapter 14. Phase 2 - the inventory must describe your real estate

Auditor will demand a **System Description** which lists every in-scope asset. Build these four sub-inventories and reconcile between them.

Inventory	Owner	Tool suggestion	Refresh cadence
Asset Inventory (HW/SW)	IT Ops	ServiceNow CMDB / Lumos / AWS Config aggregator	Monthly
Application Inventory	App Owner + CISO	ServiceNow APM / SSPM / CodeQL	Quarterly

Data Asset Inventory	CISO + DPO	DLP tools + Data catalog (Collibra / Alteryx)	Quintary
Vendor / Subservice Org Inventory	Procurement + CISO	Vanta / Drata vendor module + Splunk	Quintary

Chapter 15. Phase 3 - the gap assessment is your audit's mirror

Run a TSC-by-TSC questionnaire. Use the format below for every Common Criterion.

Borrowed from real enterprise templates

This is the same structure top-tier Big-4 SOC 2 readiness tools use. Auditor tools like **Drata**, **Vanta**, **Secureframe**, **Tugboat Logic** extend this with status workflowing (Open → In Progress → Awaiting Evidence → Ready for Audit → Evidence Approved).

Chapter 16. Phase 4 - remediation playbook (most controls you must implement)

The list below is what 90% of NBFC SOC 2 programs need to remediate. Order roughly by ROI/time-to-evidence.

Domain	Control	SOC 2 Criteria
Identity & Access	SSO + MFA everywhere (Okta/Entra ID)	CC6.1, CC6.2
Identity & Access	PAM for prod (CyberArk/BeyondTrust)	CC6.1
Identity & Access	Quarterly access reviews for all systems	CC6.3
Identity & Access	Joiners / Movers / Leavers workflow (HR-driven)	CC6.2, CC6.5
Logical Access	TLS 1.2+ enforced; TLS 1.0/1.1 disabled	CC6.6
Logical Access	AES-256 at rest (KMS-managed, 1-year rotation)	CC6.6
Logical Access	Secrets in vault (AWS Secrets Manager / HashiCorp Vault)	CC6.1
System Operations	Centralised logging (CloudTrail + VPC flow logs → SIEM)	CC7.2
System Operations	Vulnerability scanning (qualys/tenable/Nessus) monthly	CC7.1
System Operations	Patch SLA (Critical 7d, High 14d, Med 30d)	CC7.1
System Operations	EDR on all endpoints (CrowdStrike/SentinelOne)	CC6.8, CC7.2
System Operations	SIEM with 24x7 SOC (or MDR)	CC7.2, CC7.3
Change Mgmt	CAB + change tickets for all prod deploys	CC8.1
Change Mgmt	Unit + integration tests gate deployment	CC8.1
Change Mgmt	Separate dev/staging/prod; no prod creds for devs	CC6.1, CC8.1
IR	Documented IR plan + 2-hour RBI notification runbook	CC7.4
IR	Annual tabletop + 1 targeted tabletop in audit window	CC7.4
BCP/DR	Annual DR drill with RTO/RPO measured	A1.3, CC7.5
Vendor Risk	SIG Lite or SOC 2 review for all critical vendors	CC9.2
Policy Library	All policies approved, version-controlled, communicated	CC5.3
Awareness	Annual security training + phishing simulation	CC1.4, CC2.2
Data Protection	Backup encrypted + tested restore quarterly	A1.2, A1.3
Confidentiality	Data classification + labelling	C1
Processing Integrity	Daily reconciliation report for disbursements	PI1.4
Privacy	DPDP-compliant privacy notice + consent flow	P1, P2

Chapter 17. Phase 5-6 - evidence collection devices and evidence catalog

Build an **Evidence Catalog**: control → frequency → evidence type → evidence source → automated fetch / manual collection → storage location. Auditor reads this catalog at planning. Sample format:

Control	Frequency	Evidence Type	Source
CC6.2 - Joiners/Movers/Leavers	Daily	IAM access report + ticket	Okta/Entra ID + Jira
CC6.3 - Quarterly Access Review	Quarterly	Reviewed list + sign-off	Excel + Distribution list + Confluence
CC6.6 - Encryption at rest	Continuous	AWS Config rule + KMS key rotation	AWS Config rule / KMS console
CC7.1 - Vuln scan	Monthly	Scan report + remediation ticket	Qualys + Jira
CC7.2 - SIEM logs	Continuous	Log retention (≥1 year) report	Splunk / Sentinel / Wazuh
CC7.3 - IR escalation test	Quarterly	Tabletop deck + minutes + sign-off	Confluence
CC7.4 - Incident reports	Per incident	Incident ticket + RCA	PagerDuty / Jira / Confluence
CC8.1 - Change advisory board	Weekly	CAB minutes + change tickets	Jira / ServiceNow
A1.3 - DR drill	Annual	DR plan + drill report + RTO/RPO evidence	Confluence + AWS Console
CC2.2 - Security training	Annual	Completion report	KnowBe4 / LMS
CC9.2 - Vendor review	Quarterly	Vendor risk questionnaire + SOC 2 evidence	DocuSign
PI1.4 - Daily reconciliation	Daily	Reconciliation report	LMS + bank API
P1 - Privacy notice	Annual review	Privacy notice + version	Website / Confluence

Chapter 18. Phase 7 - audit fieldwork survival guide

- Pick one person to be the **Audit Coordinator** - they triage requests, route to control owners, and chase to closure.
- Use a single **Evidence Request List (ERL)** tracker in a shared spreadsheet or tool.
- Sample selection is auditor-driven. Expect ~25-30 items per control commonly tested over 6-12 months.
- Auditor tests operate-effectiveness by re-running the control and checking your evidence matches reality.
- Interviews: control owner must master their procedure as if explaining to new starter.
- Deficiencies must be remediated inside 90 days OR appear in management response; you choose.
- Do not fabricate evidence - auditor will spot the inconsistency on re-perform.

Common exceptions to watch for

(a) Change tickets without CAB sign-off, **(b)** access review evidence from spreadsheets (auditor prefers system-of-record), **(c)** SIEM logs with retention < 30 days (should be > 12 months for SOC 2), **(d)** data flows diagram that hasn't been updated for new vendors, **(e)** DR drill "annual" but no evidence occurred in observation period.

Chapter 19. Subservice organisations and Carve-Out / Inclusive methods

If a subservice org provides a control YOU rely on (AWS, KYC vendor), you have two reporting choices:

Method	What the report says	When to use
Carve-Out	Subservice org's controls except those performed by the subservice org are treated as if they were yours. Auditor tests subservice org's SOC 2 (per se)	When subservice org provides its own SOC 2 (per se)
Inclusive	Subservice org controls are treated as if they were yours. Auditor tests them as part of his/her SOC 2 and is cr	When subservice org has no SOC 2

NBFC subservice org list (typical)

- Audit-grade inventory you should prepare upfront:
- AWS (hosting, KMS, S3) - carve-out, AWS SOC 2 relied on
 - Auth0 / Okta (identity) - carve-out
 - Signzy/IDfy/Perfios (KYC, eSign) - carve-out + vendor risk review
 - CIBIL/Experian/Equifax - carve-out + vendor risk review
 - Razorpay/Cashfree/PayU (payment gateway) - carve-out
 - CleverTap/MoEngage (analytics)
 - Plaid/Yodlee (bank statement parsing) if used
 - SMS/WhatsApp gateway (Gupshup, Karix, Twilio)
- For each: list the controls you depend on them for, list the criteria (TSC) and link to their SOC 2.

Chapter 20. Complementary User Entity Controls (CUECs)

CUECs are controls the customer (user entity) must implement. Common CUECs the auditor will want to see documented:

- Customer is responsible for ensuring its own user access forms / KYC are legitimate.
- Customer controls access to downloaded reports/CSVs once outside the system.
- Customer configures its own network/firewall for accessing the NBFC API.
- Customer manages physical security of its own offices that interact with the NBFC.
- Customer addresses fraud awareness within its own employee base.

Real NBFC case study & sector-deep controls

Chapter 21. RapidLend NBFC Pvt Ltd - the case study

Profile: RapidLend is an Indian NBFC (registered with RBI, top-layer NBFC-MFI category), founded 2018, 800 employees across 6 cities. Tech: AWS-hosted microservices (EKS, RDS PostgreSQL, S3, Lambda), mobile lending app (React Native), LOS/LMS in-house, co-lending with 5 partner banks. Originations: ■720 crore / yr. Active loans: 410k borrowers.

SOC 2 Type II engagement: Big-4 auditor, observation window **01 Jan 2025 to 31 Dec 2025**, TSCs in scope: Security, Availability, Confidentiality, Processing Integrity. Total controls tested: 78.

Why TSCs were chosen

Two bank partners (co-lending) required SOC 2 as a condition precedent. The platform's largest bank partner required an unqualified Type II. **Privacy** was deferred because at the time (2024-25) all data principals were Indian residents and DPDP rules were still being notified; we needed to add a separate SOC 2 + Privacy round in the next cycle (2026).

Chapter 22. RapidLend - control-by-control reality (excerpt)

CC6.1 - Logical Access Restriction

Control: Production access to AWS is granted through AWS IAM Identity Center with SSO+MFA. Privileged access to production database requires PAM elevation (CyberArk) with 4-hour session expiry. Direct IAM user keys are forbidden; CI/CD uses IAM roles + OIDC federation.

Evidence: IAM Identity Center user/group export, MFA enrolment report per quarter, CyberArk session logs (sample 25), AWS Config rule *iam-user-no-policies-attached* green.

Auditor probe: Eng pulled 30 sample prod access requests during 2025; every one had approved ticket + ticket age < access grant < 4 hours.

CC6.3 - Quarterly Access Reviews

Control: Every quarter the InfoSec team exports an IAM user inventory, distributes to system owners; owners mark 'keep / modify / remove'; InfoSec applies changes within 10 business days.

Evidence: Distribution emails, owner sign-off sheets, follow-up change tickets.

Real challenge: Initially our 'remove' took > 30 days. We fixed by automating removal via a Lambda that consumes signed sign-off and applies the change via AWS Identity Center APIs - execution within 4 hours.

CC7.4 - Incident Response

Control: IR plan documented covering P1-P4 severity, on-call rota, RBI within-2-hour notification template, customer comms template, co-lending bank notification, post-mortem.

Real incident during observation period: 14-Mar-2025 - phishing-led credential theft on an ops engineer; SOC2 detected via AWS GuardDuty + Splunk within 7 minutes; revoked within 19 minutes; RBI notification sent at T+1h45m; post-mortem attached to Jira INC-2391.

Auditor comment: 'The 14-Mar incident actually proved the design. We re-performed tickets and SIEM queries. Effective.'

CC8.1 - Change Management

Control: Every production deploy backed by a Jira change ticket with CAB approval (or emergency change approval post-facto from ED-CTO). PRs to main branch require 2 reviewers including 1 +2/owner group; CI pipeline blocks on unit + lint + integration tests.

Evidence: Jira change query report (monthly), GitHub/GitLab merge log, CI/CD dashboard.

Common finding area: Mobile app releases via Play store do not synchronise with Jira. We connected Store API + Slack bot to log each release back to a Jira issue.

PI1.4 - Reconciliation of disbursements

Control: Daily 6 AM automated reconciliation runs to compare (a) bank CBDT statement, (b) LMS disbursed ledger, (c) co-lending split ledger. Discrepancies > █1 trigger a SEV-3 ticket.

Evidence: Reconciliation report archived daily to S3 with lifecycle 6 years (RBI record retention).

Auditor sample: Drove 25 disbursement events across 2025; each trace went through recon report, bank statement, LMS ledger, and customer's loan agreement - all matched.

A1.3 - DR drill

Control: Annual full DR drill restoring production to a secondary region (ap-southeast-1) with RTO 4 hours / RPO 15 minutes target.

2025 drill (May 17): Simulated KMS key compromise; full RDS restore from snapshot to DR region; achieved RTO 3h42m, RPO 11m. Lessons learned pushed 7 improvements to production by Q3.

Why this matters: RBI IT Framework 2023 §18 makes this not optional; it also is one of the rules auditors double-check because it is provable.

What RapidLend learned (lessons that paid off)

(a) Start with GRC automation. We showed up with a Vanta + ServiceNow GRC stack; saved 70% of evidence-collection time and pushed monthly control health to the CISO dashboard live.

(b) RBI mapping matters. Auditor complemented the SOC 2 report with a tailored RBI compliance schedule; client said it cleared procurement faster.

(c) Subservice orgs are half the risk. AWS, KYC vendor, payment gateway - we tracked each vendor's SOC 2 validity and added it to our monthly InfoSec ops review. Caught one expired SOC 2 once.

(d) Co-lending partner audits. Bank partners reserve right to on-site agility; we run an annual internal SOC 2 mock audit to keep them quiet.

Chapter 23. NBFC sector 'must-have' controls (the audit essentials list)

Area	What you must have
Lending platform integrity	LOS = source of truth for loan terms. Reconciliation against disbursement, ledger, CIBIL reports.
KYC integrity	eKYC via Aadhaar XML/OVD, video KYC storage (RBI V-CIP 2021), CIDR pull logs, PMLA §31.
Privileged access separation	Developers: zero prod access. SRE: time-bound elevation. CISO: audit-only. Database admin: read-only.
Data localisation	DPDP & RBI cross-border restrictions. Maintain pincode of all Indian PII at rest in ap-south-1.
Encryption keys	Per-tenant KMS keys; rotation evidence; HSM for critical keys (CloudHSM).
Fraud risk	CC3.3 fraud assessment; fraud analyst role separation; AML rule engine; Suspicious Transaction Reports.
Collection controls	RBI Fair Practices Code; data minimisation; call recordings access controls; vendor (collection agency) controls.
Co-lending partner data	Per-partner data vault; co-lending bank sees only its share; encrypted at rest + segregated logs.
Code of Conduct	PMLA, RBI outsourcing, ethics, anti-bribery, anti-fraud acknowledgement by all staff annually.
Vendor risk	SIG-Lite or VSA questionnaire; SOC 2 receipt from critical vendors; periodic review.
Customer grievance	RBI integrates customer's grievance portal; ticket lifecycle and turnaround SLA evidenced.
Privacy notice	DPDP-compliant; clear 'purpose' heading; explicit consent toggle; not bundled with T&C.
Retention	Loan records 5 years after closure (RBI); KYC 5 years after account closure (PMLA); logs 12 months.
Consent withdrawal	Data principal rights workflow per DPDP §8 (nominate, access, correct, erase).

Everything you can copy-paste on day 1 of your engagement

Template 1. Master Document Checklist (45 documents)

#	Document	Owner	Status
1	Information Security Policy	CISO	
2	Acceptable Use Policy	CISO	
3	Access Control Policy	CISO	
4	Password Policy	CISO	
5	Encryption & Key Management Policy	CISO + Infra Lead	
6	Data Classification Policy	CISO + DPO	
7	Data Retention & Disposal Policy	CISO + DPO	
8	Change Management Policy	IT + Engineering	
9	Vulnerability Management Policy	CISO + Infra	
10	Patch Management Policy	IT + Infra	
11	Endpoint Security Policy	CISO + IT	
12	Network Security Policy	CISO + Network	
13	Cloud Security Policy	CISO + Cloud Lead	
14	Backup & Recovery Policy	IT	
15	Incident Response Plan	CISO	
16	Incident Response Runbooks (P1-P4)	SOC Manager	
17	Business Continuity Plan	CIO + CISO	
18	Disaster Recovery Plan	Infra Lead + CISO	
19	Vendor Risk Management Policy	CISO + Procurement	
20	Third-Party / Outsourcing Policy	Compliance + Legal	
21	Privacy Notice & Policy	DPO + Legal	
22	Information Asset Inventory	CISO	
23	Risk Register	CRO + CISO	
24	Code of Conduct	HR + Legal	
25	Anti-Bribery & Anti-Corruption Policy	Legal + Compliance	
26	Whistleblower Policy	Legal	
27	Background Verification Policy	HR + Compliance	
28	Security Awareness & Training Policy	CISO + HR	
29	Bring Your Own Device (BYOD) Policy	CISO + IT	
30	Remote Work / Work-from-Anywhere Policy	HR + IT + CISO	
31	Software Development Life Cycle Policy	CTO	

32	Secure Code Review Policy	CTO + AppSec	
33	Open Source Usage Policy	CTO + Legal	
34	Mobile Application Security Policy	Product Security	
35	API Security Policy	Product Security	
36	Logging & Monitoring Policy	CISO + SOC	
37	Physical Security Policy (Office/DC)	Facilities + CISO	
38	Compliance / Regulatory Mapping Document	Compliance	
39	RBI Cyber Security Reporting Register	IT + Compliance	
40	Audit Trail / Event Log Policy	CISO + IT	
41	Penetration Testing Charter	CISO + AppSec	
42	Annual Penetration Test Report	CISO + AppSec	
43	Business Impact Analysis	CIO + CISO	
44	Records of Processing Activities (RoPA)	DPO	
45	System Description for SOC 2 Report	CISO + Engagement Partner	

Template 2. Policy Inventory & Cadence

Policy	Owner	Approver	Review Cadence	Audience
Information Security Policy	CISO	Board Audit Committee	Annual	All employees, contractors
Acceptable Use Policy	CISO	CIO	Annual	All employees
Access Control Policy	CISO	CIO	Annual	IT, Engineering
Password Policy	CISO	CIO	Annual	All employees
Encryption Policy	CISO	CIO	Annual	Engineering, IT
Data Classification	DPO + CISO	Legal	Annual	All employees
Data Retention	DPO + CISO	Legal	Annual	Engineering, Ops
Change Management	Engineering	CTO	Annual	Engineering
Incident Response	CISO	CIO	Annual	All employees, on-call
Vendor Risk	CISO	CFO	Annual	Procurement, Legal
Privacy Notice & Policy	DPO	Legal	Annual	Public
Code of Conduct	HR	Board	Annual	All employees

Template 3. Asset Inventory (multi-tab)

Tab 1 - Hardware

Asset ID	Type	Make/Model	Owner	Location	Critical?	OS	Last patch
HW-0001	Laptop	Dell Latitude 7440	Ravi S	Mumbai HQ	Yes	Win 11	12-Jul-2025
HW-0002	Laptop	MacBook Pro 14	Priya M	Bengaluru	Yes	macOS 14	20-Jul-2025
HW-0003	Server	Dell PowerEdge R750	IT-Ops	AWS-Mum	Yes	RHEL 8	01-Jul-2025
HW-0004	Router	Cisco ISR 1100	IT-Network	Mum DC	Yes	IOS XE	15-Jun-2025

Tab 2 - Application

App ID	Name	Type	Owner	Cloud?	Version	Data class	Internet-exposed
APP-101	Loan Origination System (LOS)	Internal	Lending Eng	AWS	v4.7	Confidential	No
APP-102	Loan Management System (LMS)	Internal	Lending Eng	AWS	v3.9	Confidential	No
APP-103	Customer Mobile App	External	Mobile Eng	AWS	v6.2 (iOS)	Customer PII	Yes
APP-104	Co-Lending Partner API	External	Platform Eng	AWS	v2.1	Confidential	Yes
APP-105	Agent Field Collection App	External	Collections Eng	AWS	v2.0	Customer PII	Yes
APP-106	Internal BI Dashboard	Internal	Analytics	AWS	Tableau 2024.2	Confidential	No

Tab 3 - Data Assets

Data ID	Dataset	Class	Volume	Storage	Encryption
DAT-301	Customer PII	Restricted	1.2M rows	RDS Postgres (KMS)	AES-256
DAT-302	Loan Records	Confidential	2.0M rows	RDS Postgres (KMS)	AES-256
DAT-303	KYC Documents	Restricted	850K files	S3 with KMS + bucket policy	AES-256
DAT-304	CIBIL Reports	Confidential	900K files	S3 with KMS	AES-256
DAT-305	Call Recordings	Confidential	5M files	S3 IA + lifecycle	AES-256
DAT-306	Backups	Confidential	5 TB daily	S3 + cross-region	AES-256

Tab 4 - Vendors / Subservice Organisations

Vendor ID	Vendor	Service	In-scope TSCs	SOC 2 obtained?	Risk
VEN-401	AWS	Hosting, KMS, S3 storage	CC6.1, CC6.6, A1.2, C1.2	Yes (carve-out)	Low
VEN-402	Okta	SSO + MFA	CC6.1, CC6.2	Yes (carve-out)	Low
VEN-403	CyberArk	PAM for prod	CC6.1	Yes (carve-out)	Low
VEN-404	IDfy	eKYC, V-CIP video	C1, P1, P2	Yes	Med
VEN-405	CIBIL	Credit bureau pulls	PI1.2	Self-attestation + SIG	Med
VEN-406	Razorpay	Payment gateway (payout)	PI1.4, CC6.6	Yes	Low
VEN-407	KnowBe4	Security awareness	CC1.4, CC2.2	Yes (carve-out)	Low
VEN-408	Karix SMS	OTP / comms	CC6.6, CC6.7	SIG received	Med
VEN-409	CTM / Debt collection agency	Debt collection	C1, P2, P4	Annual SIG + MSA	High

Template 4. Risk Register (NBFC relevant)

Risk register format: ISO 27005 or NIST 800-30 compliant. Likelihood × Impact → inherent → controls → residual.

#	Risk	Asset	Threat	Inherent Score	Control	Residual Score	Owner
R-001	Unauthorized admin access	LMS / LOS	Compromised admin credentials	L (15)	MFA + PAM + JIT	L (4)	CISO
R-002	CIBIL data leak	DAT-304 CIBIL Dumps	Insider exfil	H (15)	DLP + KMS + bucket policy	M (3)	DPO
R-003	Ransomware	EKS + EBS	Phishing + lateral move	H (20)	EDR + immutable backups + IR	M (8)	CISO
R-004	Aadhaar XML misuse	DAT-303 KYC	UIDAI non-compliance	H (16)	Tokenisation + access logging + audit trail	M (4)	DPO
R-005	Co-lending data confusion	Co-Lending API	Partner sees another bank's share	M (9)	Per-tenant vault + partner SLAs + filters	M (3)	Platform Eng
R-006	Lender fraud (origination)	LOS	Synthetic identity / ghost borrower	H (15)	eKYC + bureau checks + fraud score + dual approval	M (4)	Compliance
R-007	Cloud misconfiguration	AWS Org	S3 public bucket / SG 0.0.0.0/0	H (16)	AWS Config + SCP rules + weekly review	M (4)	Cloud Lead
R-008	Vendor (collection agency) breach	DAT-305 Call records	Bad actor at vendor	M (10)	Vendor SOC2 + DPA + audit (9) minimal data	M (6)	Compliance
R-009	DPDP cross-border breach	DAT-301 PII	Data exported to non-notified country	M (12)	Region-locked + SCP + monitoring	M (4)	DPO
R-010	AI/LLM data leakage	Customer support bot	Prompt injection exfiltrating PII	M (8)	Output filtering + retrieval blacklist	M (3)	Product Security

Risk scoring approach

Likelihood 1-5, Impact 1-5, Score = L × I. Map: 1-5 = Low, 6-10 = Med, 11-15 = High, 16-25 = Critical. Kill residual risks > High via additional controls, transfer via cyber insurance, or accept formally by CRO. RBI Master Direction requires formal sign-off above residual High.

Template 5. Control Matrix (TSC → Control → Evidence)

TSC / Criterion	Control Objective	Control Activity	Frequency	Owner	Evidence
CC1.1 - Integrity / Ethics	Maintain ethical culture	Annual Code of Conduct training + acknowledgement HR	Annual	HR	LMS report + signed attest
CC1.2 - Board Oversight	Board reviews cyber	Quarterly cyber committee meeting with minutes	Quarterly	CISO	Board pack + minutes
CC2.3 - External Comms	Customer notifications	Status page + RBI breach reporting SOP + customer comms template	Per event	CISO + Compliance	Status page export + tickets
CC3.2 - Risk Analysis	Maintain risk register	Quarterly risk review meetings; updates register	Quarterly	CISO + Risk	Register + meeting minutes
CC6.1 - Logical Access	Limit access to authorised users	SSO + MFA on all systems; centralised IAM	Continuous	CISO	Okta/Entra MFA report, AWS Config
CC6.2 - Auth before granting access	Authorise new access via tickets	Access provisioning via Jira change tickets + request approvals	Per request	IT	Jira query export
CC6.3 - Remove access	Revoke leaving users within 24hrs	HR feed triggers offboarding Lambda app + revoke access to systems	Per leave	IT	Lambda log + ticket
CC6.3 - Periodic review	Quarterly access review	System owners review user lists quarterly	Quarterly sign-off	Business unit heads	Sign-off sheets
CC6.6 - Encryption in transit	TLS 1.2+ enforced	TLS minimum version enforced at load balancers	Continuous	Cloud Lead	TLS scan + AWS Config rule
CC6.6 - Encryption at rest	AES-256 for all sensitive data	RDS encrypted + KMS-managed; S3 default encryption; CloudTrail logs	Continuous	Cloud Lead	CloudTrail logs + key inventory + linting report
CC6.8 - Malware protection	EDR on all endpoints	CrowdStrike deployed to 100% fleet; daily health checks	Daily	IT	CrowdStrike console export
CC7.1 - Vuln management	Vulnerability scans monthly	Tenable/Nessus scheduled scans; report to Jira	Monthly	SecOps	Scanner report + Jira tickets
CC7.2 - System monitoring	24x7 SIEM monitoring	Splunk / Sentinel with use cases + alerting	Continuous	SOC	SIEM dashboard + alert flow
CC7.3 - Security event evaluation	Triage alerts	Tiered SOC playbooks with on-call rotation	Continuous	SOC	Splunk ticket log
CC7.4 - Incident response	Respond per IR plan	Documented IR plan + Playbooks P1-P4 + IR identification	Per incident	CISO + Legal	Incident tickets + RCA
CC7.5 - Recovery	Recover from incidents	BCP/DR plan with annual full drill, tested quarterly	Quarterly / Annual	Engineering	DR drill report + restore logs
CC8.1 - Change management	All prod changes approved	CAB weekly + PR reviews + CI gates; peer change checks	Per change	Engineering	CAB minutes + Jira
CC9.1 - Risk mitigation	Business insurance for cyber	Cyber insurance policy > ₹10 crore Annual	Annual	CFO	Policy doc
CC9.2 - Vendor risk	Assess subservice orgs	SIG-Lite for all critical + SOC 2 collected	Quarterly	CISO + Procurement	SIG + SOC 2 file
A1.2 - Infrastructure capacity	Capacity monitoring + scaling	AWS ASG + auto-scaling + monthly capacity review	Continuous	Cloud Lead	Capacity dashboard
A1.3 - DR test	Annual DR drill	Restore production to DR region; document RTO/RPO	Annual	Cloud + IT	DR report + metrics
C1.1 - Confidential info identification	Data classification scheme	All assets classified; labelled	Quarterly	DPO + CISO	Classified asset list
PI1.4 - Processed as designed	Reconciliation	Daily reconciliation of disbursements	Daily	Finance + Engineering	Reconciliation report
P2.1 - Privacy purpose limitation	Use for declared purpose only	GDPR-aligned consent log; per consent	Per event	DPO	Consent log export

Template 6. Project Plan (detailed work-back schedule)

Week	Workstream	Task	Owner	Output
W01	Mobilise	Charter + sponsor sign-off	CISO	Charter doc
W01	Mobilise	Auditor selection & RFP	CFO	Engagement letter
W02	Mobilise	PM tool + RACI uploaded	PM	Tracker live
W02-W04	Scope	Build system description draft	CISO	System description v0.1
W03-W04	Inventory	Asset inventory A1-A4	CISO + IT	4-tab spreadsheet
W04-W06	Gap Assess.	TSC-by-TSC walkthrough (33+CC)	CISO + Owners	Gap register v1.0
W06-W08	Plan	Remediation roadmap	CISO	Plan with priorities
W08-W12	IAM	Roll out SSO + MFA	IT + CISO	SSO 100% users
W08-W14	Logging	Centralised logging + SIEM	SecOps	Logs to SIEM
W10-W18	Policies	Write / refresh 20+ policies	CISO	Approved policies
W12-W20	VM	Continuous vuln management	SecOps	Tool live + scan cadence
W14-W22	IR	IR plan + tabletop 1	CISO + Legal	IR plan + ISO RC1
W16-W24	DR	Build DR plan; tabletop 1; full drill 1	Cloud + IT	DR plan + drill report
W20-W26	Vendor	SIG / SOC2 collection for all vendors	CISO + Proc	Vendor pack
W22-W28	Change	Change mgmt platform + CAB	CTO	CAB weekly + system
W24-W28	Audit ready	Dry run + observation window start	PM	Audit-ready checklist 100%
W28-W78	Observation	12-month observation window (Jan-Dec 2025)	All	Evidence library
W78-W84	Audit	Auditor fieldwork + interviews + sampling	PM	Issue log
W84-W88	Report	Draft + management response + final report	CFO + CISO	Final SOC 2 Type II

Template 7. Evidence Collection Catalogue (every auditor pull)

Control	Evidence needed	Cadence	Source system	Pre-audit check
CC1.1 Ethics	CoC training report + attestation	Annual	LMS	≥95% completion
CC1.2 Board oversight	Board pack + committee minutes	Quarterly	Confluence/Drive	Cyber on agenda
CC2.3 Customer comm	Status page export	Per outage	Statuspage.io	Public URL live
CC5.3 Policy deployment	Policy acknowledgement report	Annual	LMS / DocuSign	100% onboarded staff
CC6.1 SSO+MFA	Okta/Entra MFA enrolment	Quarterly	Okta/Entra	100% staff + 100% admins
CC6.2 Ticket-based provisioning	Jira access ticket sample	Per request	Jira	≥25 sample pulled
CC6.3 Remove leavers	Offboarding ticket + run report	Per leaver	HRIS + IdP	≤24h removal
CC6.3 Quarterly review	Owner sign-off sheets	Quarterly	Confluence	All 4 quarters covered
CC6.6 TLS scan	SSL Labs A rating	Quarterly	External scan	A or A+
CC6.6 KMS evidence	KMS rotation logs + key inventory	Continuous	AWS KMS	No expired keys
CC6.8 EDR coverage	EDR coverage report	Continuous	CrowdStrike	≥99% endpoints
CC7.1 Vuln scan	Monthly scan report + remediation Jiras	Monthly	Tenable	No Critical >14d open
CC7.2 SIEM logs	Log retention & integrity report	Continuous	Splunk	≥12m retention
CC7.3 SOC alert closure	Alert closure tickets	Continuous	Splunk + Jira	MTTR < SLA
CC7.4 IR plan	IR plan + RCA for actual incidents	Annual / per incident	Confluence + Jira	RBI < 2h timing proven
CC7.5 BCP/DR	DR drill report + restore logs	Annual	Confluence + AWS	RTO/RPO met
CC8.1 CAB	CAB minutes + change tickets	Weekly	Confluence + Jira	All prod linked to ticket
CC9.1 Cyber insurance	Policy doc + renewal receipt	Annual	Finance	Coverage in force
CC9.2 Vendor SOC 2	Vendor SOC 2 report + SIG	Annual	Vanta + Drive	Past 12 months
A1.2 Capacity	Capacity dashboard snapshots	Monthly	Grafana / CloudWatch	No alerts in window
A1.3 DR drill	DR plan + drill report	Annual	Confluence	Occurred in window
C1.1 Classification	Asset classification list	Quarterly	Confluence	100% in-scope classified
PI1.4 Reconciliation	Daily reconciliation report	Daily	LMS + Bank API	≥0 unreconciled txn ≥1
P2.1 Privacy	Consent log export	Per new user	LMS + CMP	≥99% addressed

Template 8. Gap Assessment Sheet (per control)

Field	Value
TSC / Criterion code	e.g. CC6.1
Control title	e.g. Logical access restriction
Control owner (role)	e.g. CISO
Control operator (team)	e.g. IT
Current state	Implemented / Partial / Not implemented / Out of scope
Risk rating if absent	Critical / High / Medium / Low
Description of current state	1-3 sentences
Gap detail	1-3 sentences
Remediation action	1-3 sentences
Target date	DD-MMM-YYYY
Resource / cost estimate	■ / number of FTEs
Acceptance plan if no remediation	OR residual risk acceptance level
Status	Open / In Progress / Awaiting Evidence / Ready for Audit / Evidence Approved
Reviewed by	Name + date

Template 9. Subservice Org Worksheet (Carve-Out Support)

Field	Value
Vendor name	AWS India
Service provided	Hosting, KMS, S3, IAM
In-scope TSCs relied upon	CC6.1, CC6.6, A1.2
Carve-out vs Inclusive	Carve-out
SOC 2 report period	01-Oct-2023 to 30-Sep-2024
SOC 2 report received on	01-Nov-2024
Bridge letter (if gap)	Yes (Oct 2024 to Jan 2025)
Auditor name	EY
Subservice org's auditor relied upon?	Yes
Complementary subservice org controls (CSOCs) reviewed?	Yes
Penetration test / attestation?	ISO 27001 + SOC 2
DPA in place?	Yes (signed 2024)
Risk rating	Low
Reviewer / Date	CISO / 14-Jan-2025

Template 10. CUEC Worksheet

TSC	CUEC description	Disclosed in report?
CC6.1	User entity controls its own end-user authentication practices for accessing its data via our systems.	Yes
CC6.2	User entity authorises the access request via its own approval workflow before submitting.	Yes
CC6.6	User entity maintains encryption of any data it exports from our system.	Yes
A1.1	User entity manages its own devices to access our system.	Yes
PI1.4	User entity verifies accuracy of data after our processing, before relying on it.	Yes
P5	User entity responds to data principal access requests within its own responsibilities.	Yes

What auditors love to find - and what they'll hate

Chapter 24. The top 20 audit findings at NBFCs (rank-ordered)

#	Finding	Frequency	Severity
1	Spreadsheet access reviews (not evidence-of-record)	~70% of NBFCs	Med
2	MFA not on all admin / production accounts	~50%	High
3	Log retention < 90 days (RBI wants 180 days min for NBFCs infra)	~40%	High
4	CAB minutes missing for emergency / hot-fix deploys	~40%	High
5	Vendor SOC 2 reports not refreshed annually	~35%	High
6	Policy acknowledgement gaps for contractors / interns	~35%	Med
7	Data flow diagram outdated; missing new integration	~30%	Med
8	Encryption at rest claimed but actually only S3 SSE-S3 (not KMS for sensitive)	~25%	Med
9	TLS scan shows B rating because admin endpoint on TLS 1.0	~20%	Med
10	DR drill documents but not tested within SOC 2 window	~15%	High
11	On-call rota truthfully wasn't manned during weekend gap	~15%	High
12	Ransomware simulation not documented	~12%	High
13	Privacy notice still says GDPR; not updated for DPDP	~10%	Med
14	Aadhaar storage not encrypted (or tokenisation missing)	~8%	Critical
15	CIBIL report repository lacks audit logging	~8%	High
16	Production access still uses local IDs, not federated	~15%	Med
17	Backups not tested with quarterly restore drill	~25%	Med
18	Penetration test report missing remediation evidence	~20%	Med
19	RBI cyber report register shows missed 2-hour notification in a past incident	10%	Critical
20	Joint controller / co-lending data sharing without DPA	~12%	High

Chapter 25. Pro Tips - 30 habits that win audits

- ✓ 1. Show, don't tell: every control description has a corresponding evidence file and a folder path
- ✓ 2. Use one Evidence Repository (S3 bucket / Confluence space). Auditors will bookmark and pray
- ✓ 3. Standard file naming: __.pdf
- ✓ 4. Tag every evidence with the TSC criterion it supports
- ✓ 5. Pre-pull 1.5x the audit samples; if audit asks for 25, have 40 ready
- ✓ 6. Audit Coordinator must rotate - keep 2 deep backups (PM + risk lead)

-
- ✓ 7. Quarterly mock audits catch $\geq 80\%$ of findings BEFORE the real one
 - ✓ 8. Run a 'skills audit' for control owners - many don't know how to read SIEM
 - ✓ 9. Onboarding scripts MUST include SOC 2 evidence location - new joiners don't know
 - ✓ 10. Document 'why not' as well as 'do' - CUEC disclosures are key
 - ✓ 11. Build audit dashboard: % controls operational, last review, exceptions outstanding
 - ✓ 12. Tribe of Evidence Champions - 1 in each team to chase gaps
 - ✓ 13. Vendor SOC 2 monitoring: table with expiry dates, monthly review
 - ✓ 14. Maintain a 'system description' doc and review quarterly for drift
 - ✓ 15. Track change exceptions: emergency changes count must be $< 5\%$ of total
 - ✓ 16. Cloud Custodian / AWS Config rules checked monthly with auto-remediation
 - ✓ 17. DLP enforcement on S3 buckets that hold CIBIL/PII
 - ✓ 18. RBI cyber register is a sacred artefact - it must be filed timely
 - ✓ 19. Tabletops must generate ticket and RCA, even if not real incident
 - ✓ 20. DR drill must actually failover - simulated restores don't count
 - ✓ 21. Document interactions between controls (e.g., SIEM alerts trigger IR)
 - ✓ 22. Process diagrams included in system description - auditor loves them
 - ✓ 23. Use GRC tool (Vanta/Drata) - manual evidence pulls is death by spam
 - ✓ 24. Apply the 'freshness' rule: no evidence > 12 months for active controls
 - ✓ 25. Have a 'defense in depth' section - shows maturity beyond checkbox
 - ✓ 26. Customer-facing trust page with latest SOC 2 badge = sales acceleration
 - ✓ 27. Quarterly executive report (controls health, exceptions, trend)
 - ✓ 28. Mock interviews with control owners before fieldwork
 - ✓ 29. Reserve 2 weeks for management response drafting
 - ✓ 30. Celebrate the win - SOC 2 Type II earned is org resilience milestone

Last 14 days before, during, and after the audit

Chapter 26. Day -14: Audit Readiness Check

Run every item on the checklist below. Anything not 100% must be a known and managed risk.

Area	% Complete	Owner sign-off
All 33+ CC criteria: control narrative written	100%	
All selected TSC criteria: control narrative written	100%	
System description v1.0 reviewed	100%	
Evidence catalog complete with evidence-source mapping	100%	
Subservice org list frozen; SOC 2 reports on file	100%	
CUECs documented	100%	
Mock audit conducted; findings remediated or accepted	100%	
Sample evidence pulled + indexed for 1.5x sample size	100%	
Control owners trained; interview guides prepared	100%	
Auditor portal access (read-only) granted	100%	
Audit Coordinator + 2 deputies assigned	100%	

Chapter 27. Day 0-7: Fieldwork Rituals

- Daily standup 09:00 IST with auditor: yesterday's asks, today's plan, blockers
- Pull request 'evidence delivery' ticket type - SLA 24h
- Audit Coordinator Triage Board (Kanban): Open → In Progress → Delivered → Reviewed
- Weekly Issues log reviewed by CISO every Friday
- Mid-week deliverable: update risk register + audit log
- Auditor interviews: 60 minutes each, control owner + SOP printed
- Pair auditor requests with at least 3 evidence sources where possible
- If exception appears, draft management response template immediately

Chapter 28. Day 8-21: Findings & Management Response

Management response principles:

- **Don't hide exceptions.** Auditor will find them in re-perform. Disclose.
- **Quantify.** Number of affected records, transactions, or events.
- **Root cause.** Show your 5-Whys or fishbone.
- **Compensating control.** If you have one, present it; if not, propose one.
- **Owner + target close date.** Auditor needs to know you'll fix it.
- **Repeatability.** State how the exception is not systemic.

-
- Aim for zero exceptions on Privacy + CC6, CC7, CC8; spot exceptions allowed on lower-risk CCs.

Chapter 29. Day 22+: Report Delivery

Final SOC 2 Type II report structure:

- Section 1: Independent Service Auditor's Report (opinion)
- Section 2: Management's Assertion (you assert controls were effective)
- Section 3: Description of the System (you wrote)
- Section 4: Tests of Operating Effectiveness & Results (auditor's)
- Section 5: Subservice Organisations (carve-out declarations)
- Section 6: Complementary User Entity Controls (CUECs)

Opinion types to aim for

Unqualified (clean) = dream. Aim for this.

Qualified = opinion except for specific noted exceptions. Acceptable for some NBFCs at first audit.

Adverse = opinion states controls not effective. Avoid at all costs - signal to remediate deeply.

Q&A; bank - 15 questions you'll face in client or audit-manager interviews

Q1. Explain SOC 2 in one sentence.

Answer

An auditor's report on whether a service organisation's controls were designed and operated effectively against AICPA Trust Services Criteria over a defined period.

Q2. Type I vs Type II?

Answer

Type I = design at a point in time. Type II = design + operating effectiveness over 6-12 months.

Q3. Who is the user entity?

Answer

The customer relying on the SOC 2 report - typically your NBFC's bank / aggregator / B2B SaaS partner.

Q4. Subservice org - how do you treat AWS?

Answer

Carve-out: we exclude AWS controls but reference their SOC 2 in section 5 and rely on it for foundational controls (hosting, KMS, network).

Q5. What's the biggest driver of clean SOC 2 for NBFC?

Answer

Continuous evidence collection: 70% of findings are because evidence is missing, stale, or unstaged.

Q6. How does SOC 2 differ from ISO 27001?

Answer

ISO is a certifiable ISMS (3-year cycle, surveillance). SOC 2 is an attestation (typically annual). Both overlap heavily in CC; SOC 2 is report-shaped, ISO 27001 is management-system shaped.

Q7. What is a CUEC?

Answer

Complementary User Entity Control - a control the customer must run themselves for the SOC 2 to be effective.

Q8. How do you handle DPDP Act in SOC 2?

Answer

Map DPDP clauses → AICPA Privacy Criteria → specific controls. Build a privacy notice + consent flow with withdrawal. Disclose cross-border transfer controls.

Q9. What's your strategy for the 2-hour RBI incident notification?

Answer

SOC detector plays + SIEM rule for severity tags IR ticket with T+0; on-call rota auto-pages CISO + Legal within 4 minutes; RBI notification template pre-approved, sent at T+1:30 typically.

Q10. How do you scope a SOC 2?

Answer

System description first. List apps in scope (LOAN, LMS, mobile, partner API), data, infrastructure, locations, third parties, services. Restrict to a coherent system reflecting customer-facing boundary.

Q11. What tools do you love? Why?

Answer

Vanta for evidence automation + sample pulls, Splunk for SIEM, Tenable for VM, Drata for GRC workflow, AWS Config for cloud posture. Each picked because it integrates with the rest of the stack and has solid NBFC / financial customer base.

Q12. How do you inventor a cloud-only NBFC?

Answer

AWS Config aggregator for infra, ServiceNow CMDB sync, GitHub org listing for application repos, Okta/Entra for users, S3 + Macie for data. All four inventories reconcile monthly.

Q13. How do you keep your SOC 2 healthy?

Answer

Continuous control monitoring, quarterly mock audits, monthly control owner KPIs, exceptions aging tracker, annual refresh of system description, vendor SOC 2 expiry calendar.

Q14. What is a bridge letter and when is it needed?

Answer

When vendor SOC 2 report ends mid-period, vendor signs a gap-period assertion letter; we file it with their most recent SOC 2 to bridge coverage.

Q15. What makes an NBFC SOC 2 succeed in first attempt?

Answer

Top-down sponsorship, RACI clarity, evidence automation, GRC tool from week 1, mock audit every quarter, well-built system description, and disciplined subservice org management.

GLOSSARY - 60 TERMS YOU SHOULD OWN

Term	Definition
AICPA	American Institute of Certified Public Accountants - author of TSC.
Assertion	Management's written statement that controls were effective.
Availability (A)	TSC category - system uptime / performance.
Bridge Letter	Vendor letter covering gap between their SOC 2 period and your period.
Carve-out	SOC 2 reporting method that excludes subservice org controls but references them.
CC1-CC9	Common Criteria series - mandatory in every SOC 2.
CCPA	California Consumer Privacy Act.
CIP	Critical Infrastructure Protection (US); less used in NBFC context.
Confidentiality (C)	TSC category - protect confidential data.
CPA	Certified Public Accountant - licensed to issue SOC 2.
CSPM	Cloud Security Posture Management.
CUEC	Complementary User Entity Control.
CISO	Chief Information Security Officer.
DPIA	Data Protection Impact Assessment (GDPR).
DPDP	Digital Personal Data Protection Act, 2023 (India).
DLP	Data Loss Prevention.
EDR	Endpoint Detection & Response.
ERM	Enterprise Risk Management.
FaaS	Function-as-a-Service; cloud deployment model.
FAIR	Factor Analysis of Information Risk.
GSR	Group Strategy Review (Big 4 internal).
Honeypot	Decoy system to detect attackers.
Inclusive Method	SOC 2 method treating subservice org as if it were you.
IR	Incident Response.
ISAE 3000/3402	International standard for non-financial audit engagements / controls.
ISO 27001/27002	Information Security Management Systems (2022 revision).
KPI/KRI	Key Performance Indicator / Key Risk Indicator.
MFA	Multi-Factor Authentication.
MSSP	Managed Security Service Provider.
MTTD/MTTR	Mean Time To Detect/Mitigate/Respond.
NBFC	Non-Banking Financial Company.
NIST CSF	NIST Cybersecurity Framework (2.0 in 2024).
OT/ICS	Operational Technology / Industrial Control Systems.
PAM	Privileged Access Management.
PCI DSS	Payment Card Industry Data Security Standard.
PII	Personally Identifiable Information.
PI	Processing Integrity TSC.
RACI	Responsible, Accountable, Consulted, Informed.
RBI	Reserve Bank of India.
RoPA	Records of Processing Activities (GDPR Art. 30).

RPO	Recovery Point Objective.
RTO	Recovery Time Objective.
SAST/DAST	Static / Dynamic Application Security Testing.
SCIM	System for Cross-domain Identity Management.
SDLC	Software Development Lifecycle.
SIEM	Security Information & Event Management.
SIG/SIG-Lite	Standardised Information Gathering questionnaire.
SOC 1/2/3	Service Organisation Control report types.
SOAR	Security Orchestration, Automation, Response.
SSAE-18	AICPA standard governing SOC engagements.
SSO	Single Sign-On.
Subservice Org	Vendor that supports the service organisation's controls.
TSC	Trust Services Criteria (Security + A + C + PI + P).
Type I vs II	Point-in-time vs period-of-time reports.
TPRM	Third-Party Risk Management.
UIDAI	Unique Identification Authority of India (Aadhaar).
VAPT	Vulnerability Assessment & Penetration Testing.
V-CIP	Video-based Customer Identification Process (RBI).
WAF	Web Application Firewall.
Zero Trust	Security model: "never trust, always verify."

End of playbook. The control inventory is yours to lift; the templates are yours to copy; the case study is yours to emulate; the interview answers are yours to memorise. Build, ship, audit, win. - Cyber GRC Research